

TRYHACKME LAB REPORT

1. Incident Report (TryHackMe Brute It)

B. Incident Details

Field	Value
Incident ID	THM-BRUTEIT-001
Date / Time Detected (UTC)	Jun 4, 2026
Analyst Name	Diya
Client / Environment	TryHackMe Lab – Brute It
Severity	High
Status	Resolved

B.1 Executive Summary

A vulnerable web application hosted on an Apache Ubuntu server was analyzed in a simulated penetration testing environment. The attacker performed reconnaissance using Nmap and Gobuster, identified a hidden admin panel, and executed a brute-force attack using Hydra to obtain valid credentials. Further exploitation led to SSH access using a cracked RSA private key, followed by privilege escalation using a reused root password. Full root access was successfully achieved.

B.2 Timeline of Events

Timestamp (UTC)	Event	Source
11:42	Nmap scan revealed open port 80 (HTTP)	Nmap
11:50	Hidden admin panel discovered	Gobuster
12:07	Brute-force attack initiated on admin login	Hydra
12:19	Valid admin credentials discovered	Hydra output

Timestamp (UTC)	Event	Source
12:25	RSA private key found and extracted	File system
12:35	RSA key passphrase cracked	John the Ripper
12:40	SSH access gained as user "john"	SSH
12:50	Root password cracked and privilege escalation completed	Linux shell

B.3 Affected Assets

Hostname	IP Address	OS	User(s)	Criticality
Target Machine	10.49.186.138	Ubuntu Linux	admin / john / root	High

B.4 Indicators of Compromise (IOCs)

IOC Type	Value	Source / Enrichment	ATT&CK Technique
IP Address	10.49.186.138	Nmap scan	T1046 (Discovery)
Web Directory	/admin/	Gobuster	T1595 (Scanning)
Login Username	admin	Lab hint	T1078 (Valid Accounts)
Brute-force Tool	Hydra	Attack execution	T1110 (Brute Force)
SSH Key	id_rsa	File discovery	T1552 (Credentials)
Root Password	football	John the Ripper	T1110 (Credential Attack)

B.5 ATT&CK Mapping

Tactic	Technique ID	Technique Name	Evidence
Discovery	T1046	Network Service Scanning	Nmap scan
Credential Access	T1110	Brute Force	Hydra attack
Credential Access	T1552	Unsecured Credentials	RSA key extraction

Tactic	Technique ID	Technique Name	Evidence
Privilege Escalation	T1068	Exploitation for Privilege Escalation	sudo/root access

B.6 Actions Taken

Phase	Action	Timestamp	By
Reconnaissance	Performed port scan using Nmap	11:42	Analyst
Enumeration	Discovered admin panel using Gobuster	11:50	Analyst
Exploitation	Performed brute-force attack using Hydra	12:07	Analyst
Access	Gained SSH access using cracked key	12:40	Analyst
Privilege Escalation	Cracked root password and escalated to root	12:50	Analyst

B.7 Root Cause Analysis

The root cause of the compromise was weak authentication mechanisms in both the web application and SSH service. The admin panel was vulnerable to brute-force attacks due to lack of rate limiting or account lockout. Additionally, sensitive credentials were exposed through an RSA private key and weak root password, enabling full system compromise.

B.8 Recommendations

Short-term fixes:

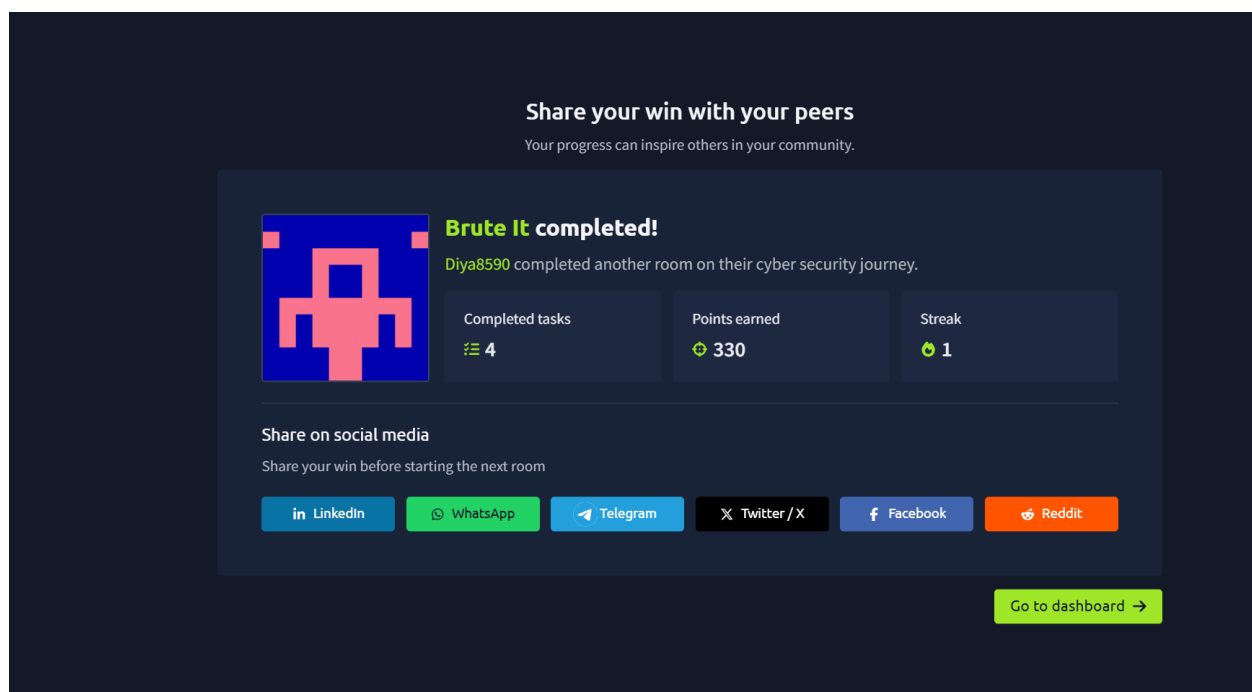
- Implement account lockout after failed login attempts
- Enforce strong password policies
- Disable password authentication for SSH
- Remove exposed sensitive files (like private keys)

Long-term improvements:

- Use MFA for admin panel access
- Harden SSH configuration (key-only authentication)
- Apply proper file permission controls
- Regular vulnerability assessments

Detection improvements:

- Monitor repeated login failures
- Detect brute-force patterns on web login forms
- Log and alert on suspicious authentication attempts



2.Incident Report (SOC Alert Triage Lab)

Incident Details

Field	Value
Incident ID	THM-SOC-ALERT-001
Date / Time Detected (UTC)	Mar 21, 2025
Analyst Name	Diya
Client / Environment	TryHackMe SOC Simulation
Severity	Mixed (Critical / High / Low)
Status	Resolved

Executive Summary

This report documents the investigation and triage of multiple SOC alerts in a simulated Security Operations Center environment. The alerts included potential data exfiltration, malware download activity, and benign developer activity. Each alert was analyzed using SOC triage methodology to classify it as either a true positive or false positive based on evidence.

Timeline of Events

Timestamp (UTC)	Event	Source
13:02	GitHub repository accessed by user	SIEM Alert
13:30	High-volume data transfer detected (Zoom)	SIEM Alert
13:58	Suspicious file download (double extension)	Endpoint Detection

Affected Assets

Hostname	IP Address	OS	User(s)	Criticality
LPT-IT-063	192.168.45.66	Windows	G.Chandler	Medium
LPT-HR-009	—	Windows	S.Conway	High
UK04/MEETINGROOM	—	Network Segment	Multiple users	Medium

Indicators of Compromise (IOCs)

IOC Type	Value	Source	ATT&CK Technique
Domain	freecatvideoshd.monster	Download alert	T1566 (Phishing)
File	cats2025.mp4.exe	Endpoint detection	T1204 (User Execution)
Data Transfer	5.8 GB to zoom.us	SIEM log	T1041 (Exfiltration)
URL	github.com/facebook/react	GitHub access	Benign activity

ATT&CK Mapping

Tactic	Technique ID	Technique Name	Evidence
Initial Access	T1566	Phishing	Malicious download
Execution	T1204	User Execution	Double extension file
Exfiltration	T1041	Exfiltration Over C2 Channel	Zoom data transfer
Discovery	T1082	System Information Discovery	GitHub access context

Actions Taken

Phase	Action	Timestamp	By
Triage	Alerts reviewed and assigned	13:02	Analyst
Investigation	Log analysis performed	13:30	Analyst
Classification	Alerts classified as TP/FP	13:58	Analyst
Closure	Alerts marked resolved	14:10	Analyst

Root Cause Analysis

The alerts were generated due to a combination of legitimate user activity and malicious phishing-based execution. One alert was caused by normal developer access to GitHub, while another was triggered by legitimate Zoom usage. However, a high-risk phishing attempt was identified through a malicious double-extension file download.

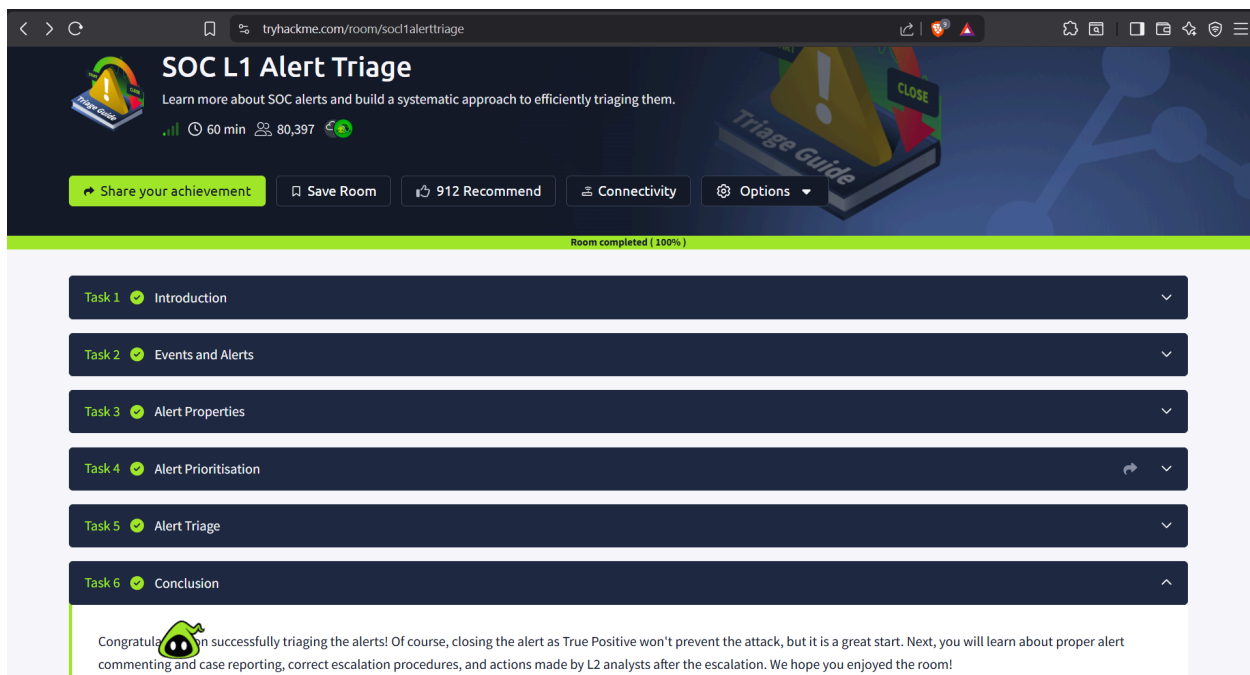
Recommendations

Short-term:

- Block malicious domains (e.g., freecatvideoshd.monster)
- Restrict execution of double-extension files
- Improve email/web filtering

Long-term:

- Implement endpoint protection for download validation
- Improve user awareness training on phishing
- Enhance SIEM rules for file masquerading detection
- Monitor abnormal file execution patterns



3.Incident Report (Phishing Analysis Fundamentals)

Incident Details

Field	Value
Incident ID	THM-PHISH-001
Date / Time Detected (UTC)	Jun 4, 2026
Analyst Name	Diya
Client / Environment	TryHackMe Lab – Phishing Analysis Fundamentals
Severity	Medium
Status	Resolved

B.1 Executive Summary

A phishing email investigation was conducted to identify indicators of malicious activity within a suspicious email message. The analysis included reviewing email headers, message source data, sender information, originating IP addresses, attachment metadata, and phishing characteristics.

The investigation revealed an email spoofing attempt impersonating a trusted organization. Email header analysis exposed the true sender details and originating IP address. The email contained social engineering elements commonly associated with phishing attacks, including brand impersonation and deceptive sender information.

The email was classified as a phishing attempt and appropriate detection indicators were documented.

B.2 Timeline of Events

Timestamp (UTC)	Event	Source
11:30	Suspicious email received	Email Client
11:35	Email header reviewed	Thunderbird
11:40	Message source inspected	Email Source Analysis
11:45	X-Originating-IP identified	Header Analysis

Timestamp (UTC)	Event	Source
11:50	Attachment metadata analyzed	Source Review
12:00	Sender spoofing confirmed	Email Investigation
12:10	Phishing indicators documented	Analyst
12:15	Investigation completed	Analyst

B.3 Affected Assets

Asset Type	Identifier	Description	Criticality
Email Account	Recipient Mailbox	Targeted User	Medium
Email Gateway	Mail Infrastructure	Message Delivery Path	Medium
Workstation	User Endpoint	Potential Victim System	Medium

B.4 Indicators of Compromise (IOCs)

IOC Type	Value	Source
Sender Email	support@teckbe.com	Email Header
Originating IP	103.234.236.83	X-Originating-IP
Technique	Email Spoofing	Header Analysis
Threat Type	Phishing	Email Content
Attachment	Base64 Encoded PDF	Email Source

B.5 ATT&CK Mapping

Tactic	Technique ID	Technique Name	Evidence
Initial Access	T1566.001	Phishing: Spearphishing Attachment	Malicious Email
Initial Access	T1566.002	Phishing: Spearphishing Link	Embedded Links
Credential Access	T1586	Compromise Accounts	Spoofed Identity
Reconnaissance	T1598	Phishing for Information	Social Engineering

B.6 Actions Taken

Phase	Action	By
Identification	Reviewed email headers	Analyst
Analysis	Inspected message source	Analyst
Investigation	Verified sender details	Analyst
Validation	Identified phishing indicators	Analyst
Documentation	Recorded IOCs and findings	Analyst
Closure	Classified as phishing attempt	Analyst

B.7 Root Cause Analysis

The phishing email leveraged sender spoofing and social engineering techniques to appear legitimate. The attacker attempted to impersonate a trusted organization in order to gain user trust.

Analysis of email headers revealed discrepancies between the displayed sender information and actual message origin. The originating IP address and sender domain indicated the message was not sent from the legitimate organization being impersonated.

B.8 Recommendations

Short-Term Actions

- Verify sender addresses before responding.
- Inspect email headers for suspicious indicators.
- Avoid opening unexpected attachments.
- Confirm requests through alternative communication channels.

Long-Term Improvements

- Implement SPF, DKIM, and DMARC validation.
- Deploy advanced email filtering solutions.
- Conduct phishing awareness training.

- Enforce multi-factor authentication (MFA).

Detection Improvements

- Alert on spoofed sender domains.
- Monitor emails with suspicious originating IPs.
- Detect double-extension attachments.
- Correlate phishing indicators across email logs.

